

타노시미 보안 취약점 점검 보고서 (Grade 2, with CodeQL)

- 점검일: 2026-10-05
- 점검 대상: `main fe43d74` (PR #93 CodeQL 도입 직후, Grade 1 수정 PR #91 반영 상태)
- 점검 도구: GitHub CodeQL 2.27.1, `security-extended` 규칙 (Java 120개 · JavaScript 103개)
- 조치: PR #94 (경고 #1 수정)
- 이전 보고서: `tanoshimi_보안취약점_grade1.md` (수동 점검 8건, PR #91 에서 수정)

1. 요약

구분	결과
CodeQL 경고	19건 (Java 13 · JavaScript 6)
이번 조치	경고 #1 (외부 CDN 스크립트) 수정 → <code>main</code> 재분석에서 fixed 확인
남은 경고	18건 - 아래 분류 결과 실제 취약점 1건 (#5-#6, 같은 문제), 나머지는 낮은 영향·개발용 코드·오탐

분류	경고 번호	건수
수정 완료	#1	1
실제 취약점 - 조치 필요	#5, #6 (파티방 사진 다운로드 링크 <code>javascript:</code> URL)	2
실제이나 영향 낮음	#7-#8-#9 (숫자 형변환), #10 (언어 쿠키 Secure), #11 (개발용 로그에 비밀번호)	5
영향 거의 없음	#14~#19 (로그 인젝션)	6
오탐	#2-#3-#4 (본인 파일 미리보기), #12-#13 (mock 날씨)	5

Grade 1 과의 관계: Grade 1 의 8건(XSS 2건·권한 누락 등)은 PR #91 에서 고친 뒤라 이번 CodeQL 결과에는 나오지 않는다. 반대로 Grade 1 수동 점검에서 놓친 파티방 다운로드 링크 문제(#5-#6)를 CodeQL 이 찾았다. 권한 검사 누락 같은 논리 문제는 CodeQL 규칙으로는 잘 잡히지 않으므로 두 점검은 서로 보완 관계다.

2. 수정한 경고

#1 [중간] 신뢰할 수 없는 출처의 스크립트 로드 - 수정 완료

- 규칙: `js/functionality-from-untrusted-source`
- 위치: `src/main/resources/templates/fragments/layout.html:64-65`
- 내용: 모든 화면이 쓰는 공통 레이아웃이 웹소켓 라이브러리(sockjs, stomp)를 무결성 검사(`integrity` 속성) 없이 외부 CDN(jsdelivr, cdnjs)에서 불러왔다.
- 영향: CDN 이나 그 경로가 오염되면 변조된 스크립트가 **모든 화면**에서 사용자 권한으로 실행된다.
- 조치 (PR #94): 저장소에 이미 있던 `static/vendor/sockjs.min.js`, `static/vendor/stomp.min.js` 를 쓰도록 변경. CDN 파일과 내용이 같다(줄바꿈만 다름, sockjs-client 1.6.1 · stomp.js 2.3.3).
- 검증: 로컬 서버에서 메인·계획표·파티방·메시지·마이페이지가 `/vendor/*.js` 를 불러오고(200) CDN 참조 0건, 웹소켓 엔드포인트 `/ws/info` 200. 머지 후 `main` CodeQL 재분석에서 **fixed** 처리.

3. 조치가 필요한 경고

#5·#6 [높음] 파티방 사진 다운로드 링크에 **javascript:** URL 주입 (저장형 XSS)

- 규칙: **js/xss-through-dom**
- 위치: **src/main/resources/templates/party/room.html:630, 633** (사진 보기 모달)
- 내용: 파티방 사진 카드의 **data-img** 값(게시글 **thumbnailUrl**)을 모달 이미지 **src** 와 다운로드 버튼 **href** 에 그대로 넣는다. 그런데 **thumbnailUrl** 은 게시글 작성·수정 API(**POST/PUT /api/posts**)에서 클라이언트가 보낸 문자열을 검증 없이 저장한다(**PostService.java:225, 239**).
- 공격 시나리오: 파티원이 API 로 **thumbnailUrl** 을 **javascript:...** 로 바꾼 게시글을 파티에 연결한다 → 다른 파티원이 파티방에서 그 사진을 열고 "다운로드" 를 누르면 스크립트가 실행된다.
- 영향: 피해자 권한으로 임의 동작(Grade 1 #1 과 같은 수준). 클릭이 필요하고 같은 파티원만 노릴 수 있어 범위는 제한적이지만 실제로 재현 가능한 구조다.
- 권고 조치:
 - 서버: **thumbnailUrl** 을 이 서비스가 발급한 업로드 경로(**/uploads/...**)나 **http(s)** URL 만 허용하도록 검증(게시글·파티 썸네일 공통)
 - 화면: 모달에서 **href/src** 에 넣기 전에 프로토콜이 **http(s)** 또는 같은 출처 경로인지 확인
- 상태: 미조치 (이번 요청 범위 밖 - 별도 PR 권장)

4. 실제이나 영향이 낮은 경고

번호	규칙	위치	판단	권고
#7	java/tainted-numeric-cast (critical)	PlannerController.java:204	요청값 dayIndex(int) 를 byte 로 변환. 범위를 넘으면 값이 넘쳐 엉뚱한 날짜로 처리됨. 편집권 보유자만 호출 가능, 자기 파티 일정에만 영향	dayIndex 를 여행 일수 범위로 검증
#8·#9	java/tainted-numeric-cast (critical)	TripPlannerService.java:222	일정 이동 API(PATCH /api/planner/items/{id})의 startMinute-durationMinute 를 검증 없이 short 로 변환. 넘치면 음수 시각 등 잘못된 일정이 저장됨. 편집권 보유자만, 데이터 무결성 문제	0~1440분 범위 검증 (일정 추가 API 의 @Min 처럼)
#10	java/insecure-cookie	LoginSuccessHandler.java:67	언어 설정 쿠키(TANOSHIMI_LANG)에 Secure 속성 없음. 민감 정보가 아니라 영향 낮음	HTTPS 배포 시 세션 쿠키 secure: true 와 함께 Secure-HttpOnly 지정
#11	java/sensitive-log	LogEmailSender.java:18	개발용 메일 발송기(app.email.provider=log)가 인증번호·임시 비밀번호를 로그에 그대로 남김. 개발 편의를 위한 의도된 동작이지만, 운영에서 log 로 켜져 있으면 로그만 보고 계정을 탈취할 수 있음	운영 환경은 반드시 smtp 사용, log 모드면 기동 시 경고 또는 운영 프로필에서 차단

5. 영향이 거의 없는 경고 - 로그 인젝션

번호	위치	판단
#14	EmailVerificationService.java:62	이메일을 mask() 해서 기록하고, 이메일은 @Email 검증을 거쳐 줄바꿈이 들어갈 수 없음
#15-#16	LogEmailSender.java:13, 18	개발용 발송기. 이메일 검증으로 줄바꿈 불가
#18-#19	SmtplibEmailSender.java:51, 53	mask() 처리 + 이메일 검증
#17	MockGeminiClient.java:14	mock AI 클라이언트가 프롬프트(사용자 입력 포함)를 로그에 남김. 줄바꿈으로 가짜 로그 줄을 만들 수 있으나 개발용 mock 전용

권고: 운영 로그를 보안 감사에 쓸 계획이면 로그 패턴에서 메시지의 줄바꿈 문자(CR-LF)를 다른 문자로 치환하거나(logback %replace) JSON 로그로 전환.

6. 오탐

번호	위치	판단
#2-#3-#4	party-create.js:10, post-write.js:30, post-detail.js:157	사용자가 자기 PC에서 고른 파일을 URL.createObjectURL() 로 만든 blob: 주소를 미리보기 에 넣는 코드. HTML 로 해석되지 않고 다른 사람에게 전달되지도 않음
#12-#13	MockWeatherClient.java:41	가짜 날씨 생성기가 좌표로 난수 시드를 계산. 개발용 mock 이고 값이 넘쳐도 시드만 달라짐

오탐은 GitHub Security → Code scanning 에서 "Dismiss → False positive" 로 닫아 두면 이후 목록이 깔끔해진다(저장소 쓰기 권한으로 가능).

7. CodeQL 운영 메모

- **실행:** main 대상 PR, main 푸시, 매주 월요일 03:00(KST) - [.github/workflows/codeql.yml](#)
- **결과 위치:** 저장소 Security → Code scanning. 경고마다 Copilot Autofix 로 수정 제안 가능
- **PR 결과는 일부만 보인다:** PR 분석은 그 PR 에서 바뀐 코드 위주로 경고를 보여 준다. 전체 경고는 main 분석 결과에서 확인할 것 (PR #93 확인 때 PR 결과만 보고 "Java 0건" 으로 잘못 보고한 적이 있어 기록해 둔다)
- **Default setup 과 동시 사용 불가:** 저장소 설정에서 CodeQL Default setup 을 켜면 이 워크플로의 결과 업로드가 거부된다

8. 다음 조치 우선순위

1. #5-#6 썸네일 URL 검증 (실제 XSS) - 별도 PR
2. #11 운영 환경에서 log 메일 발송기 사용 차단 (배포 전 필수)
3. #7~#9 계획표 시간·날짜 값 범위 검증
4. 오탐 5건 Dismiss 처리, 로그 인젝션은 운영 로그 정책 정할 때 함께 처리
5. Grade 1 남은 권고(CSP unsafe-inline, remember-me 키 교체 등)와 함께 배포 전 점검